



ShieldAI_{vciso}

The Virtual CISO Platform

Affordable today. A managed-security platform at scale.

COMPREHENSIVE BUSINESS PLAN

Consolidated with Market Analysis, Competitive Analysis & Financial Model

Confidential · September 2026

Prepared by Xandu Limited, LLC

Contents

1. Executive Summary

Key Highlights

2. The Problem & Market Opportunity

2.1 The SMB Security Gap · 2.2 Market Size & Headline Figures · 2.3 Market Sizing (TAM/SAM/SOM) · 2.4 Why Now

3. Product & Platform

3.1 What the Customer Gets · 3.2 The Scoring Engine · 3.3 The Role of AI

4. Strategy: Wedge to Platform

4.1 The Wedge · 4.2 The Expansion · 4.3 The Platform — The Analyst Console

5. Business Model

5.1 Revenue Streams · 5.2 Pricing Tiers · 5.3 Unit Economics

6. Financial Projections

7. Competitive Landscape & Defensibility

7.1 The Landscape · 7.2 Detailed Competitor Profiles · 7.3 Head-to-Head Comparison · 7.4 Why We Win · 7.5 Competitive Risks & Watch Items

8. Marketing & Customer Acquisition Strategy

8.1 Target Customer & Positioning · 8.2 Acquisition Channels · 8.3 Lifecycle & Expansion Marketing · 8.4 Metrics & Marketing Discipline

9. Product Roadmap & Future Vision

Phase 1 Live Today · Phase 2 This Raise · Phase 3 Scale · Phase 4 Expanding AI Autonomy & Feature Depth

10. Founder & Team

10.1 Founder — Derrick Brooks · 10.2 Team Today · 10.3 Year 1 Hiring Plan · 10.4 Certification & Training Program · 10.5 Team Growth Plan

11. The Ask & Use of Funds

12. Risk Analysis & Mitigation

13. Summary

SECTION 1

Executive Summary

A full-time CISO costs \$200,000–\$400,000 a year. Nearly half of small businesses have no security budget at all — yet their insurers, customers, and regulators now require a real security program. ShieldAIvCISO closes that gap.

ShieldAIvCISO is a virtual Chief Information Security Officer (vCISO) platform for small and mid-sized businesses (SMBs). It delivers a complete, continuously-managed security program — risk scoring, written policies, a prioritized roadmap, compliance mapping, awareness training, and executive reporting — at a price a small business can actually afford.

Our strategy is a deliberate wedge-to-platform progression. We begin with a free assessment and an affordable, largely self-serve tier ladder that delivers immediate value and proves the model. As clients grow, we layer human expertise on top: cybersecurity engineers who use ShieldAIvCISO to run full, managed CISO programs for a portfolio of clients — with the software (and an AI co-pilot) doing the heavy lifting so a small team can protect a large book of businesses. This is how we move from a low-cost tool to a high-value managed-security platform without a linear increase in headcount.

ShieldAIvCISO is powered by frontier AI for analysis and content generation, but our defensibility does not rest on the AI itself. It rests on four things: a proprietary, deterministic security-scoring engine built on the NIST Cybersecurity Framework that produces explainable, auditor- and insurer-trustworthy results; a human-in-the-loop model in which qualified engineers review and approve work before it reaches the client; the proprietary assessment data and client relationships that compound over time; and direct-to-SMB distribution at a price point the market's best-funded players — Cynomi, Vanta, Drata, Secureframe, Scrut Automation, and Oneleet — have each left structurally uncontested (Section 7).

Since this plan was last revised, the platform moved well beyond the self-serve wedge: the analyst console once described as a working mockup is now live in production, and dozens of the capabilities in Section 3 shipped alongside it — full control-level mapping across all 12 compliance frameworks, native cross-platform endpoint agents, an integrations marketplace, and a live “vs. Oneleet” competitive comparison, among others. Section 9's roadmap and Section 10's hiring plan have been updated accordingly.

This document consolidates ShieldAIvCISO's full investor picture into a single reference: the business plan, sourced market analysis, detailed competitive profiles, and financial model outputs, alongside a customer-acquisition strategy, an expanded product vision, and the founding team.

Key Highlights

Metric	Detail
Target market	U.S. SMBs with employees, prioritizing regulated and insured segments
Core category	Virtual CISO (vCISO) — ~\$2B+ today, growing 12–15%+ annually
Demand driver	Cyber-insurance, customer security requirements, and regulation forcing SMBs to act
Model	Five-tier ladder — Free \$0 / Starter \$159 / Growth \$349 / Guided \$699 / Managed vCISO \$1,950 — land-and-expand into engineer-run managed programs
Differentiation	Deterministic NIST scoring engine + human-in-the-loop + direct-to-SMB reach nobody else in the category has

Metric	Detail
Unit economics	\$0.28/client/month AI cost; blended gross margin expanding from ~12% (Y1) to ~74% (Y3)
Stage	Working product live in production — all 12 compliance frameworks now control-mapped; native cross-platform endpoint agents; threat intelligence, vendor risk, employee training, and a unified compliance calendar all live; analyst and admin consoles live with full client-interaction parity; billing infrastructure in place
Team	Founder-led; a part-time engineer has been building the now-live platform and converts full-time on this raise closing; a Year 1 hiring plan adds 8 roles (Section 10)
Next milestone	Execute the Year 1 core-team hiring plan (Section 10); complete agent code-signing for wide, trusted distribution; begin SOC 2 audit preparation

This plan reflects ShieldAIvCISO's current direction: the self-serve product is built and functioning in production; this raise funds the team that staffs and scales the managed-services platform layer it enables.

SECTION 2

The Problem & Market Opportunity

2.1 The SMB Security Gap

Small businesses face the same threat landscape as enterprises — ransomware, phishing, business email compromise, supply-chain attacks — but lack the budget, expertise, or time to respond. They are caught in a structural bind: too big to ignore security, too small to afford a dedicated leader. A full-time CISO costs \$200,000–\$400,000 or more per year, while the foundational tools and expertise cost roughly the same whether a business has 10 employees or 100 — so the per-employee burden falls hardest on the smallest firms.

- 47% of businesses with fewer than 50 employees have no cybersecurity budget at all (StrongDM / CrowdStrike, 2025).
- 51% have no security measures in place; one-third rely on free, consumer-grade tools.
- Only 34% have a formal incident response plan (Guardz, 2025).
- Only ~13% conduct proactive security audits, and only ~1 in 5 performs annual penetration testing.
- Small businesses represent roughly 43% of all cyberattacks, and SMB incident rates rose ~47% year over year.

The cost of inaction is severe and quantifiable: IBM data shows a tested incident-response plan reduces breach cost by approximately \$232,000, and prevention investment returns consistently exceed 7x. A foundational program costing \$5,000–\$15,000 a year would save hundreds of thousands in the event of a breach — yet the businesses that spend nothing are the ones that pay the most.

2.2 Market Size & Headline Figures

ShieldAI vCISO sits in the virtual CISO category, inside the broader SMB cybersecurity market. The figures below are sourced for direct citation in investor conversations — when pressed on a number, “estimates range from X to Y depending on how you scope it; here’s the source I’m using” is a stronger answer than a single suspiciously-precise figure.

Metric	Figure	Source
US small businesses	36.2 million (99.9% of all US businesses)	SBA Office of Advocacy, 2025
— of which have employees	~5.8M employer firms (30.4M are solo/nonemployer)	SBA Office of Advocacy, 2025
SMBs with no cybersecurity budget (<50 employees)	47%	StrongDM / CrowdStrike, 2025
SMBs with no security measures at all	51%	StrongDM, 2025
SMBs with a formal incident response plan only	34%	Guardz, 2025
Global SMB cybersecurity spending (by 2026)	\$109 billion, growing ~10%/yr	Analysis Mason
vCISO market (2025)	~\$2.0–2.9B, growing 15%+ CAGR	Multiple research firms
U.S. cyber-insurance market	~\$3.9B (2025), ~22% CAGR	Market Research Future
Full-time CISO cost	\$200K–\$400K+/year	Industry standard
Avg. data breach cost, small business	~\$120K (some sources cite far higher)	Total Assure, 2025

Metric	Figure	Source
Cyber positions unfilled globally	3.4 million	Industry (talent shortage)
ShieldAI vCISO pricing ladder	\$0 (Free) to \$1,950/mo (Managed vCISO)	ShieldAI vCISO production, September 2026

vCISO market estimates vary by research firm — from roughly \$1.06B to \$2.89B for 2024–25, with forecasts ranging from \$1.5B to \$12B by the early 2030s — because firms scope the category differently. Every credible source agrees on direction: double-digit annual growth, driven by escalating threats, a 3.4-million-person global cybersecurity talent shortage, and tightening compliance.

2.3 Market Sizing (Bottom-Up: TAM / SAM / SOM)

- **TAM:** The global vCISO category, ~\$2B+ and growing 12–15%+ per year — the market we directly serve.
- **SAM:** ~5.8M U.S. employer businesses, narrowed to regulated/insured/supply-chain segments (a conservative 10–20% → roughly 600K–1.2M businesses). At a blended program value in the low thousands per year, this is a multi-billion-dollar serviceable market.
- **SOM:** A modest, credible early capture — e.g., 1% of a 600K-business SAM at a few thousand dollars per year per client — represents a business on the order of \$20M+ in annual recurring revenue, reached over a 3–5 year horizon via the free-to-managed motion.

For reference, the 3-Year Financial Model (Section 6) projects ~1,610 total paying clients and ~\$10.1M in annualized ARR by the end of Year 3 — roughly 0.1–0.3% of the conservative SAM, well inside the SOM range above.

2.4 Why Now

The decisive shift is that demand is no longer driven by whether small businesses care about security — it is being forced on them by three external pressures converging at once:

- **Cyber-insurance as gatekeeper:** Insurers now require proof of specific controls (MFA, incident response, etc.) before issuing or renewing policies. 63% of SMBs saw premiums rise 200%+ in 2025, and businesses under \$25M in revenue filed 64% of all cyber-insurance claims — so insurers are tightening precisely on our target segment.
- **Customer-driven requirements:** Larger customers increasingly push security questionnaires and insurance requirements down to their small vendors. Without a demonstrable program, small businesses lose contracts.
- **Expanding regulation:** HIPAA, CMMC (defense supply chain), the FTC Safeguards Rule, and state privacy laws now carry real penalties — reaching deep into the small-business tier. CMMC 2.0's Phase 2 begins November 10, 2026 — seven weeks from this plan's date — making it a concrete, dated forcing function for the defense-manufacturing vertical, not an abstract future deadline.

On the supply side, AI has only recently become capable enough to deliver expert-level security analysis and documentation at a cost that makes serving the small-business segment economically viable. The need and the means have arrived at the same moment.

SECTION 3

Product & Platform

3.1 What the Customer Gets

From a short, structured assessment, ShieldAIvCISO produces a complete security program through a unified dashboard. The core deliverables:

- **Security assessment:** a conversational intake plus a structured, NIST-mapped checklist that captures the business's context and current posture.
- **Deterministic risk score:** an explainable security-posture score (see 3.2) with a per-function breakdown.
- **Prioritized roadmap:** ranked actions with effort, impact, cost, and ownership — including immediate quick wins.
- **Professional policy library:** complete, formatted, ready-to-use policy documents (Acceptable Use, Incident Response, Access Control, Data Classification, and more), downloadable as Word files and tailored to the business, with client-facing edit and version history.
- **Compliance mapping:** gap analysis against all 12 supported frameworks — NIST CSF, CIS Controls v8.1, HIPAA Security Rule, SOC 2, PCI DSS v4.0.1, ISO 27001, NIST 800-171, CMMC 2.0 (including Level 3's NIST SP 800-172 enhanced requirements), NIST 800-53 (Low, Moderate, and High baselines), FTC Safeguards, GDPR, and State Privacy — every one of them now control-mapped, with remediation traceable to a specific control and the assessment answer that produced it.

Since the platform's initial launch, the following capabilities shipped into production and are included from the tier noted in Section 5.2:

- **Threat intelligence:** real, checkable CVE exposure (via the National Vulnerability Database and CISA's Known Exploited Vulnerabilities catalog) matched to the client's actual software stack, plus dark-web and breach exposure monitoring once a domain is verified, and passive external attack-surface discovery.
- **Endpoint monitoring:** a permanently read-only agent with one-click, pre-configured installers for Windows, macOS, and Linux; detects real antivirus/EDR posture across major vendors (not just Microsoft Defender), guest accounts, legacy SMBv1, and RDP exposure.
- **Identity & access posture:** native, read-only connectors for Microsoft 365/Entra ID, Google Workspace, and Okta — MFA/2-step-verification coverage, privileged accounts without MFA, conditional-access policy gaps, and stale accounts — plus Zoom meeting-security settings.
- **Vendor risk management:** an ongoing vendor registry with AI-assisted responses to incoming customer security questionnaires, reviewed by an analyst at Guided tier and above.
- **Employee training:** real AI-generated slide content and a server-graded quiz per module — no client-side score fabrication — plus a quarterly phishing-simulation program.
- A unified compliance calendar surfacing every policy, training, vendor-reassessment, and framework deadline coming due in one place.
- **An integrations marketplace:** security-tool findings ingestion (SIEM/EDR, plus a SARIF adapter covering GitHub code scanning, Semgrep, Snyk, Trivy, and CodeQL), productivity and collaboration platforms (Slack, Microsoft Teams, Zoom, Google Meet), task trackers (Jira, Asana, Trello), identity directories, and a cloud-posture connector for AWS and Azure.
- A public, shareable trust page for prospects and customers, and an in-app Support Center combining ticketed requests with Mastermind chat.
- Incident response workflows, a recommended tool stack, board-ready executive reporting (with on-demand regeneration reflecting live client progress), and Mastermind AI Q&A — live at the Starter tier and up, scoped to what that client's plan includes and to their own data only.

3.2 The Scoring Engine — Our Core IP

ShieldAIvCISO's differentiator is a deterministic risk-scoring engine built on the NIST Cybersecurity Framework. Unlike an AI that guesses a number, the engine computes a posture score across the five NIST functions — Identify, Protect, Detect, Respond, and Recover — each weighted and scored from the structured assessment. The same inputs always produce the same score, and every point traces to a specific control.

This matters commercially: an insurer, auditor, or enterprise customer can trust an explainable, repeatable score in a way they would never trust an opaque AI output. The scoring methodology is proprietary and improves as our assessment dataset grows. A CI-enforced integrity guard fails the build if any framework's control mapping lacks a documented scoring method.

As of this update, all 12 supported frameworks are control-mapped — up from 9 of 12 when this plan was last revised — with zero unbacked claims shipped to clients. GDPR and State Privacy were promoted from AI-assisted drafting to full control-mapped assessments in September 2026; NIST 800-53 was extended from a Low-only baseline to include Moderate and High; and CMMC now assesses the full Level 3 requirement set, including the NIST SP 800-172 enhanced controls the highest-tier defense-industrial-base contractors are held to.

3.3 The Role of AI

Frontier AI powers the analytical and generative work — interpreting the assessment, drafting tailored policies, generating training and reporting, and (in the platform layer) assisting our engineers. The architecture is model-flexible and routes work to the model best suited to it: Anthropic's Claude for reasoning and writing (with a silent fallback role keeping every generation path working if a secondary provider's API is unavailable), Google Gemini for threat intelligence and search grounding, and OpenAI's GPT-4o for tool recommendations and training content. Crucially, the AI accelerates expert work rather than replacing expert judgment — which is central to both our quality bar and our liability posture (see Section 9 for how this evolves).

SECTION 4

Strategy: Wedge to Platform

4.1 The Wedge — Self-Serve Product

The entry point is a free assessment, followed by an affordable, largely self-serve tier ladder. A business completes an assessment, receives a real posture score and a complete program, and can generate and download professional policies — immediate, tangible value at a fraction of the cost of a consultant. This wedge gets businesses in the door at zero-to-low cost, proves the model, and builds the assessment dataset that strengthens our scoring engine.

4.2 The Expansion — Managed vCISO Programs

As clients grow or face greater compliance demands, they graduate to managed plans in which a ShieldAIvCISO cybersecurity engineer runs their security program on an ongoing basis. This is higher-value, higher-retention recurring revenue, and it is where the human-in-the-loop model delivers both quality and trust.

4.3 The Platform — The Analyst Console

The engine of scale is an internal analyst console: a command center where each engineer manages a portfolio of client businesses, strictly scoped to their assigned clients only. From a single interface an engineer monitors every client's posture and trend over time, sees live status from the read-only monitoring agents deployed in client networks, communicates directly with clients through two-way chat, resolves compliance-answer conflicts against real telemetry, and reviews and approves the AI's work before it ships. An integrated AI co-pilot — ShieldAIvCISO Mastermind — is strictly advisory: it triages threats, diagnoses issues, and surfaces compliance gaps, but has no inbound command channel and cannot act on a client's environment. One engineer can do what previously required a whole team, without ever giving the AI the ability to act unilaterally.

This console is live in production today — not a mockup. An engineer (or the founder, acting as one) can already open any assigned client's full workspace, take the same actions a client can take on their own account with every action logged, resolve a compliance conflict, and hand off cleanly. What this raise funds is staffing it: bringing on the cybersecurity engineers who will run client portfolios through it full-time (Section 10).

The AI does the first 80%. The engineer adds the high-value 20% — judgment, accountability, and the client relationship. That blend is our margin and our quality bar.

SECTION 5

Business Model

5.1 Revenue Streams

- **Self-serve subscriptions** (Starter, Growth) — low-cost, high-volume entry tiers; the wedge.
- **Guided subscriptions** — self-serve plus periodic engineer touch, the bridge to fully managed.
- **Managed vCISO plans** — engineer-run programs; the primary recurring-revenue engine.
- **Training delivery add-on** — \$40/month standalone add-on for Starter clients; bundled free at Growth tier and above.
- **Additional compliance framework add-on** — \$49.99/month per framework beyond a plan's included count, available Starter through Guided; a new, low-marginal-cost expansion-revenue lever added since the last revision of this plan.
- **Channel / partnerships** — referrals from cyber-insurers, MSPs, and professional-services firms whose clients are required to demonstrate controls (expanded in Section 8).
- **Add-ons** — compliance-readiness packages, cyber-insurance documentation, and specialized policy work.

5.2 Pricing Tiers

Pricing is set to undercut traditional human-only vCISO retainers — which typically run \$2,500–\$11,600/month for SMB clients, and can run considerably higher for regulated engagements — while remaining more complete than automated-only tools. Because AI performs the heavy lifting at a measured cost of \$0.28 per client per month, ShieldAIvCISO can offer a free entry point and price every paid tier for real SMB budgets while still holding healthy margins as the business scales (see 5.3).

Tier	Price/mo	What it includes	Target customer
Free	\$0	Security assessment and posture score only	Top-of-funnel; zero-friction entry
Starter	\$159	Full program generation, policy library, endpoint monitoring, and Mastermind Q&A — no engineer time	Micro-businesses; the wedge
Growth	\$349	Expanded policy and endpoint coverage, full training program access, downloads/exports	Growing SMBs formalizing their program
Guided	\$699	Growth, plus periodic engineer review, compliance tracking, and check-ins	SMBs with active compliance needs
Managed vCISO	\$1,950	A ShieldAIvCISO engineer runs the security program end-to-end, with full Mastermind access	Regulated / insured / supply-chain SMBs

A \$40/month training delivery add-on and a \$49.99/month per-framework add-on are available on qualifying tiers (see 5.1). Mastermind Q&A is included Starter tier and up, scoped strictly to each plan's accessible features and to that client's own data.

The ladder is designed for land-and-expand: a business can start at \$0 and grow into managed plans as trust builds and compliance demands increase. The Managed tier deliberately sits at or below the bottom of the traditional retainer range — a fractional CISO at a fraction of the cost.

5.3 Unit Economics — The Scalability Engine

The defining economics are at the Managed tier, where the analyst console and AI co-pilot let a single cybersecurity engineer manage roughly 25 clients with a high-touch service level.

Metric	Value
Managed price	\$1,950 / month
Clients per engineer	~25 (enabled by the AI-amplified console)
Revenue per engineer	~\$585,000 / year
Fully loaded engineer cost	~\$140,000 / year
AI + infrastructure cost	\$0.28 / client / month (measured production figure)
Gross contribution per engineer	~\$445,000 / year (~76% margin)

This corrects an earlier planning estimate that assumed \$15/client/month in AI cost — roughly 50x the measured figure. At the per-engineer level, AI cost is now immaterial (~\$84/year against \$585,000 in revenue), and the gross-contribution margin is a function almost entirely of engineer utilization, not AI spend.

Because the company carries real payroll (product engineers, leadership, sales & marketing, and G&A) ahead of revenue in the early months, the blended, company-wide margin is lower than the per-engineer figure above and expands over time:

Blended Margin	Year 1	Year 2	Year 3
Gross Margin	~12%	~58%	~74%
EBITDA Margin	~(147)%	~2%	~44%

Year 1 figures above reflect the prior, smaller team-size assumption; Section 10.3's expanded Year 1 hiring plan should be reconciled against the companion 3-Year Financial Model workbook, which is expected to modestly deepen the Year 1 EBITDA figure while leaving the Year 2–3 trajectory intact. This is the crux of the investment thesis regardless: revenue scales with the client book while engineer headcount grows far more slowly, because the software does the heavy lifting. See Section 6 and the companion workbook for the full monthly build.

SECTION 6

Financial Projections

The following is an illustrative three-year ramp built from a full monthly model (see the companion 3-Year Financial Model workbook), reflecting the five-tier pricing ladder, measured AI costs, and the expanded Year 1 hiring plan in Section 10.3.

	Year 1	Year 2	Year 3
Free clients (top of funnel)	500	1,800	4,500
Starter clients	90	300	750
Growth clients	40	150	400
Guided clients	25	100	260
Managed clients	15	60	200
Total paying clients	170	610	1,610
Team headcount (all roles)	9	17	26
Revenue (full year)	~\$0.3M	~\$2.0M	~\$6.5M
ARR (annualized run-rate, year-end)	~\$0.9M	~\$3.5M	~\$10.1M
Gross Margin	~12%	~58%	~74%
EBITDA Margin	~(147)%	~2%	~44%

Full-year revenue and year-end ARR run-rate are shown separately because the client base ramps throughout each year. Team headcount reflects the updated Year 1 hiring plan in Section 10.3 (9 total at Year 1 end, up from a prior 5-person planning estimate) and the role-level Year 2–3 build-out in Section 10.5; the client and revenue rows above are otherwise unchanged from the prior model. The key dynamic: Year 3 ARR is roughly 11x Year 1 ARR while headcount grows under 3x — the signature of a platform rather than a consultancy.

Under the prior team-size assumption, the \$900,000 seed raise (Section 11) was modeled to never be fully exhausted, with cash reaching its low point around Month 18 before the business turns cash-flow positive, consistent with Series A readiness in the Month 22–24 window. The Use of Funds table in Section 11 has been restructured around the expanded Year 1 hiring plan below; the underlying monthly cash-flow build should be re-run against the companion workbook to confirm the precise runway figure before it is repeated to investors as a specific number.

The companion 3-Year Financial Model workbook (referenced throughout this plan) contains the full monthly build across seven linked tabs — Assumptions, Client Growth Model, Headcount & Payroll, Monthly P&L, Annual Summary, Cash Flow & Runway, and Unit Economics — so every figure above can be traced back to its driving assumption. That workbook is maintained separately from this document and should be updated to match Section 10's headcount plan.

SECTION 7

Competitive Landscape & Defensibility

7.1 The Landscape

Oneleet is the primary competitor ShieldAIvCISO tracks most closely. It is the one well-known name in the category pairing automation with real human security expertise — a dedicated compliance manager, in-house penetration testers — rather than shipping pure self-serve software, which makes it the closest conceptual match to ShieldAIvCISO's own human-in-the-loop model. A factual, sourced “ShieldAIvCISO vs. Oneleet” comparison is already live on the marketing site, and the detailed profile below extends it.

Beyond Oneleet, the other most-cited names in vCISO and GRC software split into two categories, neither of which sells directly to a small business at a small-business price:

- **AI-native vCISO platform, sold through service providers:** Cynomi — the small business never sees or chooses it.
- **Compliance / GRC automation, sold to venture-funded technology companies:** Vanta, Drata, Secureframe, and Scrut Automation — priced and built for cloud-native startups chasing an audit, not Main Street SMBs.

Every well-funded name in the category, Oneleet included, sells either through a service-provider channel or to venture-funded technology companies at 4–50x ShieldAIvCISO's price. None is built, priced, or staffed to win a direct small-business sale today — that gap is the market ShieldAIvCISO is built for.

7.2 Detailed Competitor Profiles

Oneleet

Category: Compliance-as-a-Service — automation plus a dedicated human compliance manager and in-house security team

Positioning: Markets explicitly against “compliance theater” — the claim that real security work (manual penetration testing, code scanning, cloud posture, agent-based monitoring) is the product, and compliance evidence follows as a byproduct

Target Customer: Startups through large technology enterprises (6,000+ employees) pursuing SOC 2, ISO 27001, HIPAA, PCI DSS, GDPR, or one of roughly ten more listed frameworks

Pricing Model: No public or self-serve pricing — every engagement is a custom quote gated behind a demo call. Independent pricing trackers estimate \$8,000–\$60,000+/year, typically starting around \$12,000/year for a small team and exceeding \$50,000/year for a mid-market SaaS company running multiple frameworks. Separate, commonly reported implementation costs sit on top: onboarding up to \$5,000, cloud/integration configuration \$2,000–\$15,000, SSO setup \$1,000–\$5,000, and evidence migration \$2,000–\$8,000. There is no free trial.

Strengths: manual penetration testing performed by Oneleet's own security experts, with retesting logged directly as audit evidence — real human offensive-security work, not automated-only scanning; native SAST/DAST code scanning; cloud posture integrations across AWS, GitHub, and Google Cloud; an agent-based monitoring layer that flags overprivileged accounts and unenforced MFA; strong independent review scores for usability and support.

Why it doesn't compete directly with ShieldAIvCISO: built and priced for venture-funded technology companies with an engineering stack and a SOC 2 sales motion, not a 20-person dental practice or manufacturer; frameworks are worked sequentially, one at a time, rather than in parallel; the audit relationship is managed off-platform by Oneleet with limited direct auditor-portal access for the client; and every price point requires a sales call — there is no way for a small business to see a number, or even try the product, before talking to sales.

Cynomi

Category: AI-native vCISO platform for MSPs, MSSPs, consultancies, and telcos

Founded / HQ: 2020, Tel Aviv, Israel — with offices in the UK and USA

Funding: \$37M Series B, April 2025 (Insight Partners, Entrée Capital co-lead; Canaan, Flint Capital, S16VC participating). Reported 3x ARR growth in 2024, 4.5x in 2023

Target Customer: The service provider (MSP/MSSP), not the end small business

Pricing Model: Per-seat / per-client platform licensing sold to the MSP; never billed to the small business directly

Strengths: the category leader by funding, growth, and brand recognition among MSPs; turns CISO-level methodology into guided workflows a non-security technician can execute; broad and fast-expanding framework coverage. In June 2026 Cynomi launched “AI Coworkers,” contesting ShieldAIvCISO’s “AI advises, humans act” framing directly — addressed as a deliberate trust and liability posture, not a capability gap, in Section 7.4.

Why it doesn't compete directly with ShieldAIvCISO: Cynomi has no direct-to-small-business product or brand presence; its output quality depends on the MSP operating it, whereas ShieldAIvCISO’s engineers review every deliverable; and its wholesale distribution model is structurally difficult to reverse into a direct-to-business motion without channel conflict with its own MSP customers. Cynomi’s most-cited weakness is the lack of a cross-client portfolio dashboard — ShieldAIvCISO’s analyst console already addresses this directly.

Vanta

Category: Compliance automation / GRC platform

Target Customer: Venture-funded technology companies pursuing SOC 2, ISO 27001, or HIPAA for enterprise sales

Pricing: Quote-based; 2026 street pricing runs roughly \$10,000–\$80,000+ per year

Strengths: the most recognized name in the compliance-automation category, with the widest native integration library; strong self-serve trust-report and continuous-monitoring experience for engineering-led teams.

Why it doesn't compete directly with ShieldAIvCISO: priced and built for companies with a cloud engineering stack to connect, not a 20-person medical practice with on-prem systems and no dedicated IT staff; delivers evidence collection and a trust report, not a full CISO program — no tailored written policies, no prioritized remediation roadmap, no ongoing human-led program management; no published, small-business-accessible price point.

Drata

Category: Compliance automation / GRC platform

Target Customer: Engineering-heavy startups needing deep automation and a smooth audit workflow, primarily for SOC 2

Pricing: Quote-based; 2026 street pricing runs roughly \$7,500–\$100,000+ per year

Strengths: strong auditor network and Audit Hub workflow that reduces back-and-forth during a formal audit; deep integration count (300+) valuable for complex technical stacks.

Why it doesn't compete directly with ShieldAIvCISO: the same structural mismatch as Vanta — built for a company with an engineering stack to monitor, not a small business whose gap is policy, process, and a security roadmap it can actually execute; no human-delivered program management.

Secureframe

Category: Compliance automation / GRC platform

Target Customer: First-time compliance teams and smaller startups wanting a guided, hand-held path to SOC 2 or ISO 27001

Pricing: Two plans (Fundamentals and Complete); 2026 street pricing starts around \$7,500/year and runs past \$80,000/year

Strengths: the most guided, hand-holding onboarding of the three major compliance platforms; includes some advisory/consulting touch in its packages.

Why it doesn't compete directly with ShieldAIvCISO: still priced and scoped for a technology company chasing an audit, not a Main Street small business managing insurer and regulator pressure; guided means guided through a compliance audit workflow, not an ongoing, engineer-reviewed security program with policies, training, and executive reporting.

Scrut Automation

Category: AI-powered GRC / multi-framework compliance automation

Founded: 2021; global operations spanning the US and India

Funding: \$20.5M total raised, including a \$10M round in 2024 (Lightspeed, MassMutual Ventures, Endiya Partners)

Target Customer: 50–500 employee mid-market SaaS companies pursuing multiple compliance frameworks at once

Pricing: Quote-based; typical platform cost runs roughly \$15,000–\$40,000/year, bundling frameworks and modules

Strengths: bundled multi-framework pricing is a genuine advantage for a company juggling SOC 2, ISO 27001, and HIPAA at once; AI-assisted remediation guidance (Scrut Teammates) is a real automation step beyond pure evidence collection.

Why it doesn't compete directly with ShieldAIvCISO: explicitly positioned above early-stage-startup pricing and below late-stage enterprise pricing — the mid-market SaaS sweet spot, not the small, non-technology business ShieldAIvCISO serves; requires meaningful GRC background to configure.

7.3 Head-to-Head Comparison

Company	Buyer	Typical Annual Price	Delivery Model	Human Oversight	Direct to SMB?
Oneleet	VC-funded tech co.	\$8K–\$60K+ (custom quote only)	Managed platform + in-house security team	Yes — dedicated compliance manager & pentesters	No
Cynomi	MSP / MSSP	Not sold to SMB	Platform + MSP labor	Varies by MSP	No
Vanta	VC-funded tech co.	\$10K–\$80K+	Self-serve platform	None (self-serve)	No
Drata	VC-funded tech co.	\$7.5K–\$100K+	Self-serve platform	None (self-serve)	No
Secureframe	VC-funded tech co.	\$7.5K–\$80K+	Guided platform	Light advisory add-on	No
Scrut Automation	Mid-market SaaS	\$15K–\$40K	Self-serve platform	None (self-serve)	No
ShieldAIvCISO	Small business, direct	\$0–\$23,400 (\$0–\$1,950/mo)	AI program + engineer review	Every deliverable reviewed	Yes

7.4 Why We Win

- **Proprietary scoring methodology:** explainable, repeatable, and trusted by insurers and auditors — not an opaque AI guess.
- **Human-in-the-loop:** expert review makes output trustworthy enough to sell and materially limits liability — a layer none of the four self-serve compliance platforms above offer at any price, and one Oneleet only offers at 4–50x ShieldAIvCISO's cost.
- **Compounding data and relationships:** every assessment and managed client makes the system smarter and stickier.
- **Direct-to-SMB reach at an SMB price:** the lane every well-funded competitor above has left structurally open — Cynomi sells through MSPs, Oneleet and Vanta/Drata/Secureframe/Scrut sell to venture-funded technology companies at 4–50x ShieldAIvCISO's price, with Oneleet alone adding \$5,000–\$28,000+ in separate onboarding and integration fees no ShieldAIvCISO client ever pays.
- **Genuine feature parity in places competitors assume small businesses don't need:** native identity and MFA posture monitoring across Microsoft 365, Google Workspace, and Okta — the same capability Oneleet markets as a differentiator — plus parallel, not sequential, assessment across all 12 supported frameworks.
- The AI is the commodity; the system around it — methodology, workflow, engineers, data, and direct distribution — is the moat. A well-funded competitor cannot trivially replicate the whole system.

7.5 Competitive Risks & Watch Items

- **Oneleet moving downmarket:** as the closest model match, a stripped-down, self-serve, publicly-priced Oneleet tier aimed at smaller companies is the single most direct threat to monitor — it would erase the pricing-transparency and no-sales-call advantages this plan leans on hardest.
- **Cynomi expanding downstream:** with \$37M in fresh capital, 3x ARR growth, and the June 2026 “AI Coworkers” launch, Cynomi could plausibly launch a direct-to-business SKU. Its MSP-channel economics and brand make this a real but not immediate threat — worth monitoring each funding/product announcement.

- **A stripped-down SMB tier from Vanta, Drata, or Secureframe:** all three have signaled downward price pressure from smaller entrants; a simplified, lower-priced SKU aimed at smaller companies is conceivable within 12–24 months.
- **New AI-native entrants:** the compliance-automation category is attracting well-funded challengers (Sprinto, Thoropass, ComplyJet, Hyperproof) that could eventually target true SMBs; none currently does, but the category is moving fast.
- **RealCISO**, flagged as the closest self-serve small-business-track entrant to watch: like Oneleet and Cynomi, it is built and sold primarily through an MSP/MSSP channel with opaque, quote-based pricing rather than direct to the end business — not a near-term direct threat, but the nearest thing to one among the platform-only names.
- **Mitigation:** ShieldAIvCISO's moat is the combination — deterministic scoring, human review, and direct SMB distribution — not any single feature a competitor could copy in isolation. Speed of client and data accumulation, plus the feature-depth roadmap in Section 9, is the best defense against a fast-follower.

SECTION 8

Marketing & Customer Acquisition Strategy

ShieldAIvCISO's acquisition strategy is built around a simple insight from Section 2.4: our buyer is rarely searching for security out of general concern. They act when an external party — an insurer, a customer, a regulator — forces the question. Marketing's job is to be present at that moment of forced decision, and priced low enough that the free assessment removes any reason to delay.

8.1 Target Customer & Positioning

The primary buyer is an owner, office manager, or operations lead at a 10–250 employee business in a regulated, insured, or supply-chain-exposed vertical — healthcare practices, financial advisories, manufacturers, and similar professional and operational businesses. This buyer is not a security expert, is budget-conscious, and is almost always triggered into action by an external requirement rather than proactive interest.

Positioning leads with the trigger, not with fear: “The security program you're being asked to prove you have — without hiring a CISO.” Messaging is anchored to the specific forcing function (an insurance renewal, a customer's security questionnaire, a compliance deadline) rather than generic cybersecurity anxiety, which this buyer has learned to tune out. Against Oneleet specifically, the sharpest available contrast is process, not just price: a prospect can see ShieldAIvCISO's exact tier pricing and run a free assessment today, with no demo call required — Oneleet requires a sales conversation before a prospect sees a number at all.

8.2 Acquisition Channels

Channels are prioritized by intent and cost, cheapest and highest-intent first:

- **Cyber-insurance broker & carrier partnerships** — the single highest-intent channel, since insurers are already requiring these controls (Section 2.4). Partner with regional brokers and MSP-adjacent insurance MGAs to become the vendor a broker recommends when a client's application is denied or a premium spikes for lack of controls.
- **Referral partnerships with adjacent, non-competing professionals** — accountants, business attorneys, and MSPs/IT providers who serve the same SMBs but don't offer a dedicated security program. A modest referral fee or revenue share for a warm introduction is far cheaper than paid acquisition, and these referral partners are motivated to keep their clients out of trouble, not to compete with us.
- **Vertical trade association partnerships & sponsorships** — dental and healthcare-practice associations, community bank and credit union associations, manufacturer trade groups (tied directly to CMMC deadlines), and financial-advisor associations. These are dense, pre-qualified audiences that map directly onto the compliance frameworks already built (HIPAA, CMMC, SEC/SOC 2).
- **Compliance-deadline-driven content & campaigns** — timed campaigns around known regulatory triggers (CMMC rollout phases, state privacy law effective dates, FTC Safeguards Rule enforcement actions) create urgency without resorting to fear-based generic messaging.
- **SEO & content marketing around the free assessment** — since the wedge is the free assessment itself, invest in content that ranks for the exact searches this buyer makes when the trigger hits (“do I need a HIPAA risk assessment,” “CMMC requirements for small manufacturers,” “what does my cyber insurance policy require”), routing directly to the assessment as the call to action.
- **Narrowly-targeted paid search & social** — small, tightly-scoped campaigns on the highest-intent search terms and vertical-specific channels, measured strictly against free-to-paid conversion rather than top-of-funnel volume.

8.3 Lifecycle & Expansion Marketing

Marketing does not stop at signup. Because the product itself is a five-tier ladder, automated lifecycle messaging nudges a Free assessment toward Starter, and Starter or Growth clients toward Guided or Managed as their compliance needs deepen — a new contract requiring SOC 2, an insurance renewal, a CMMC deadline. This internal, expansion-focused marketing is as important as external acquisition, since upgrading an existing client requires far lower cost than winning a new logo, and it is the mechanism behind the Section 6 client-mix shift toward higher tiers over time.

8.4 Metrics & Marketing Discipline

Every channel is tracked on customer acquisition cost (CAC), free-to-paid conversion rate, tier-upgrade rate, and payback period. Underperforming channels are cut within a quarter rather than scaled on hope. Given the client ramp modeled in Section 6 (170 → 610 → 1,610 paying clients across three years), the strategy is deliberately built to diversify beyond any single channel by Year 2 — broker and association partnerships are relationship-built and slower to scale but far more durable and lower-cost than paid acquisition, which is why they are prioritized first even though they take longer to activate. Executing this channel plan at pace is the Sales & Marketing hire's core mandate (Section 10.3).

SECTION 9

Product Roadmap & Future Vision

Phase 1 — Live Today

What shipped before this raise, now in production and covered in full in Section 3:

- Conversational intake + structured NIST checklist; deterministic posture scoring.
- AI-generated security program: roadmap, policies, compliance mapping across all 12 control-mapped frameworks, workflows, training, executive reporting.
- Professional policy generation with Word export and client-facing version history; five-tier billing infrastructure.
- Native, read-only, cross-platform monitoring agents with one-click installers and real AV/EDR detection.
- Threat intelligence (CVE/KEV, dark-web exposure, passive attack-surface discovery), identity & MFA posture monitoring, vendor risk management, employee training with server-graded quizzes, quarterly phishing simulation, a unified compliance calendar, an integrations marketplace, a public trust page, and an in-app Support Center.
- The analyst and admin consoles, live in production with full client-interaction parity, two-way chat, and conflict resolution — not a mockup (Section 4.3); Mastermind Q&A live at Starter tier and up.
- Security hardening consistent with SOC 2 preparation: request rate limiting, standard security headers, a scoped CORS allowlist, and closed SSRF/OAuth gaps across every third-party connector.

Phase 2 — This Raise: Staffing and Hardening the Platform

- Execute the Year 1 core-team hiring plan (Section 10.3) — 3 cybersecurity engineers, an AI engineer, a web developer, an IT manager, a sales & marketing lead, and HR/admin support — and run the accompanying Certification & Readiness Program (Section 10.4).
- Complete agent code-signing for wide, trusted distribution (Windows SmartScreen and macOS Gatekeeper both require it before broad client rollout).
- Begin SOC 2 audit preparation, building on the security hardening already shipped in Phase 1.
- Close the two verified, scoped Oneleet feature gaps: a vetted third-party penetration-testing referral path, and a Google Cloud posture connector alongside the existing AWS/Azure integration (see the accompanying Claude Code brief for the detailed spec).
- Activate the go-to-market channels in Section 8 behind the new Sales & Marketing hire.

Phase 3 — Scale

- Channel partnership scaling (insurers, MSPs, trade associations — see Section 8) for low-CAC distribution.
- Broaden integration and cloud-provider coverage further; expand client base and verticals.
- Deepen automation across the modules that shipped in Phase 1, following the client and revenue growth modeled in Section 6.

Phase 4 — Expanding AI Autonomy & Feature Depth

Beyond this raise, two future directions extend the platform — both are additive to the trust model in Section 4.3 and Section 12, not a departure from it.

More autonomous AI, within the same human-approval gate

Today, AI analysis and generation happen when a client or engineer requests them. The next evolution is AI that works more continuously and independently on the analysis and drafting itself: continuously re-scoring posture as new agent telemetry or threat intelligence arrives rather than waiting for a manual trigger, autonomously drafting

updated policies or remediation steps in response to a new threat or a configuration change, and proactively surfacing emerging risks to the assigned engineer before a client has to ask. In every case, this is autonomy in what the AI analyzes, drafts, and recommends — never in what it is permitted to do unilaterally in a client's environment. The human-approval gate before anything ships to a client, or changes anything in their systems, is a permanent trust and liability boundary (Section 12), not a temporary technical limitation we intend to remove.

Feature depth that meets — and beats — the compliance-automation category

Section 7 shows that Oneleet, Vanta, Drata, Secureframe, and Scrut Automation have each built genuinely sophisticated automation — deep cloud and SaaS integrations, continuous evidence collection, broad framework libraries, and, in Oneleet's case, real human penetration testing. ShieldAIvCISO's roadmap explicitly targets matching that depth: expanding integrations for continuous evidence collection where a client does have a cloud stack, a scoped path to real penetration testing through a vetted partner (Phase 2), and speeding generation and remediation cycles. The difference is not that we build less — it's that we deliver the same or greater automation depth at a fraction of the price, with the human-reviewed program and direct-to-SMB distribution those platforms don't offer. Better versions of the category's best features, on our foundation, not instead of it.

SECTION 10

Founder & Team

10.1 Founder — Derrick Brooks



Derrick Brooks

Founder & CEO, Xandu Limited, LLC

Former U.S. Navy Lieutenant Commander · 20+ years in risk management, compliance, and IT infrastructure · CISSP · CISM · CompTIA Security+

Derrick Brooks is the founder and CEO of ShieldAIvCISO, built under Xandu Limited, LLC. A former U.S. Navy Lieutenant Commander with over 20 years in high-stakes risk management, compliance, and IT infrastructure, he has built enterprise security programs from the ground up, administered budgets exceeding \$200,000, and led cross-functional teams of up to 195 personnel — consistently delivering measurable results, including attack-surface reductions of up to 80% through Zero Trust architecture, Azure cloud migration, and automated vulnerability management.

Critically for a security founder, Derrick is not only a strategist but a hands-on practitioner. He has conducted penetration testing across enterprise web applications, cloud infrastructure, and connected-device APIs, uncovering and remediating tens of thousands of vulnerabilities for organizations including a major automotive manufacturer. This offensive fluency, paired with mastery of the compliance frameworks that drive buying decisions — NIST, RMF, CMMC, ISO 27001, and FedRAMP — means he understands both what the product must do technically and why customers will pay for it.

Credentials: CISSP, CISM, CompTIA Security+. Dual M.S. in Cybersecurity (National University); MBA in IT Management (Southern New Hampshire University); doctorate in Cybersecurity in progress (Westcliff University) — reinforcing frontline experience with ongoing academic research and keeping ShieldAIvCISO positioned at the leading edge of the field.

The market opportunity is structural: enterprise-grade security leadership has long been priced out of reach for the millions of small and mid-sized businesses that face the same threats as large enterprises but lack a CISO. Derrick's disciplined military leadership, proven ability to build and scale teams, and rare command of the full security stack — from boardroom strategy to code-level execution — position him to build a category-defining company and give investors confidence in both the vision and the execution behind it.

10.2 Team Today

ShieldAIvCISO is being built by Xandu Ltd. The product is already developed and functioning — including the analyst console and monitoring agents Section 4.3 and Section 9 describe as live, not mocked up — demonstrating execution capability and meaningfully de-risking the technical plan.

Alongside Derrick, ShieldAIvCISO already has a part-time security/software engineer contributing to the codebase today, who is prepared to convert to a full-time role immediately once this raise closes. **This means the first cybersecurity engineer hire in the Year 1 plan below is not a cold search** — it is activating a known, already-embedded technical resource who helped build the very console and agent platform the managed offering runs on, which meaningfully de-risks Section 10.3's hiring plan relative to a founder hiring cold into an unfamiliar codebase.

10.3 Year 1 Hiring Plan

This raise funds a specific, eight-role Year 1 core team — not a generic “engineering and sales” headcount line. Every role carries a minimum bar of a relevant four-year degree plus an active, field-appropriate certification, and every hire enters ShieldAIvCISO's Certification & Readiness Program described in Section 10.4 for any gap between what they hold at hire and the target credential for their role.

Role	Start (Y1)	Minimum Qualifications	Certification Target	Est. Cost
Cybersecurity Engineer (Hire 1 — converts the existing part-time engineer)	Month 1	Bachelor's degree in Cybersecurity, Computer Science, Information Assurance, or documented equivalent military/practical experience	Portfolio target: CISSP, CISM, CISA, CompTIA Security+, CEH, CySA — Security+ or equivalent minimum at hire	\$140,000/yr
AI Engineer	Month 1	Bachelor's degree in Computer Science, Data Science, or AI/ML	AWS Certified Machine Learning – Specialty or Google Professional ML Engineer (or equivalent)	\$160,000/yr
Web Developer	Month 3	Bachelor's degree in Computer Science or documented equivalent practical experience	A recognized full-stack/cloud developer certification (e.g., AWS Certified Developer)	\$110,000/yr
Sales & Marketing	Month 5	Bachelor's degree in Marketing, Business, or Communications	A recognized marketing/sales credential (e.g., HubSpot Inbound, Google Ads/Analytics)	\$90,000/yr
IT Manager	Month 7	Bachelor's degree in Information Technology or Computer Science	ITIL Foundation and CompTIA Security+	\$115,000/yr
Cybersecurity Engineer (Hire 2)	Month 8	Same as Hire 1	Same as Hire 1	\$140,000/yr
HR/Admin	Month 10	Bachelor's degree in Human Resources or Business Administration	SHRM-CP or PHR	\$75,000/yr
Cybersecurity Engineer (Hire 3)	Month 12	Same as Hire 1	Same as Hire 1	\$140,000/yr

Roles are staggered through the year rather than hired simultaneously — the AI Engineer and first Cybersecurity Engineer anchor Month 1 since they extend and staff the already-live platform immediately; the remaining roles follow as the client book, compliance workload, and headcount itself create the need for them. At full run-rate (Year 2 on), the eight roles total approximately \$970,000/year fully loaded; the staggered Year 1 schedule above brings the actual Year 1 cash cost to roughly \$598,000, which Section 11's Use of Funds table rounds to \$603,000 to leave a small buffer.

10.4 Certification, Exam-Readiness & On-the-Job Training Program

Every cybersecurity engineer ShieldAIvCISO hires arrives with a relevant degree and at least one active certification — CompTIA Security+ at minimum. The target certification portfolio for the engineering team is CISSP, CISM, CISA, Security+, CEH, and CySA: a deliberately broad set spanning security management (CISSP, CISM), audit and governance (CISA), technical baseline (Security+), and offensive/defensive practice (CEH, CySA).

Few working engineers hold all six on day one — CISSP, CISM, and CISA each require roughly five years of relevant experience for full certification, with associate-level status available while that experience is completed. Rather than requiring the impossible at the job posting stage, ShieldAIvCISO runs a structured program:

- Funded exam vouchers and prep-course access for every certification in the target portfolio, plus proctoring fees and a funded retake if needed.

- Protected weekly study time built into each engineer's schedule — not an unpaid expectation layered on top of client work.
- Direct mentorship from Derrick Brooks, who holds CISSP, CISM, and Security+ himself, plus peer mentorship as more of the team certifies.
- Structured on-the-job training through the live analyst console: new engineers shadow real client portfolios under a certified engineer's supervision before taking on their own, and every deliverable they produce is reviewed and approved before it reaches a client — the same human-in-the-loop model the product is built on (Section 4.3) doubles as the training model for the team that runs it.
- A defined timeline: Security+ or equivalent is the minimum bar at hire; engineers without it are not hired into a client-facing role. Each engineer is expected to add one additional certification from the target portfolio per year until the full set is reached, fully funded by ShieldAIvCISO.

The same principle — a real credential in the relevant field, funded ongoing certification where a gap exists — applies to every other Year 1 hire. The AI Engineer, Web Developer, IT Manager, Sales & Marketing, and HR/Admin roles each carry their own minimum degree-plus-certification bar (Section 10.3) and the same funded professional-development policy, scaled to what's standard in their field.

10.5 Team Growth Plan

The Year 1 team above is the foundation, not the ceiling. Headcount scales with the client book — cybersecurity engineers in particular track the ~25-clients-per-engineer unit economics in Section 5.3 against the Managed- and Guided-tier client counts projected in Section 6.

Role	Year 1 (end)	Year 2 (end)	Year 3 (end)
Founder/CEO	1	1	1
Cybersecurity Engineers	3	6	10
AI Engineer	1	2	2
Web Developer	1	2	3
IT Manager	1	1	2
Sales & Marketing	1	3	5
HR/Admin	1	2	3
Total headcount	9	17	26

Year 3's 10 cybersecurity engineers cover the ~200 projected Managed-tier clients (Section 6) at the ~25-clients-per-engineer ratio with headroom for the 260 Guided-tier clients' periodic review needs. Year 3 ARR of ~\$10.1M against 26 total employees is roughly \$388K of ARR per employee — in line with a scaling managed-services-plus-software business. This table supersedes the prior 5/13/23 headcount planning estimate; the companion 3-Year Financial Model workbook should be updated to match before it is next shared with investors.

SECTION 11

The Ask & Use of Funds

ShieldAIvCISO is raising \$900,000 in seed funding to fund the transition from a working self-serve product to a staffed, managed-security platform over the next 18–24 months.

Use of Funds	Amount	%
Core team hiring — Year 1 build-out (8 roles, staggered; Section 10.3)	\$603,000	67%
Continued platform engineering (agent code-signing & wide distribution, integration hardening, SOC 2-readiness engineering)	\$117,000	13%
Certification, Exam-Readiness & On-the-Job Training Program (Section 10.4)	\$36,000	4%
Go-to-market & channel partnerships (Section 8)	\$81,000	9%
Operations, SOC 2 audit prep, legal & compliance	\$45,000	5%
Working capital reserve	\$18,000	2%

This reallocates capital the prior plan earmarked for “converting the analyst console from mockup to live” — that build is now complete (Section 4.3) — toward accelerating the team build-out above. Engineering, GTM, and operations line items are correspondingly leaner than in the prior version of this plan because headcount now funded directly (the Sales & Marketing and IT Manager hires, in particular) absorbs work those categories previously had to buy externally.

Under the prior, smaller team-size assumption, this capital was modeled to take ShieldAIvCISO to Series A readiness in the Month 22–24 window — a managed-services platform in production, the first cohort of engineers running client programs, an ARR run-rate crossing \$3M, and proven managed-tier retention and unit economics — without the raise ever being fully exhausted. The Use of Funds table above reflects the expanded Year 1 hiring plan; the monthly cash-flow build in the companion financial model workbook should be re-run against it to confirm the precise runway and cash low-point before that specific figure is repeated to investors again.

A full-time CISO costs a quarter-million dollars a year. ShieldAIvCISO delivers that protection for the price of a subscription — and the platform lets a handful of our engineers protect thousands of businesses.

SECTION 12

Risk Analysis & Mitigation

Risk	Mitigation
AI output accuracy / hallucination	Deterministic scoring engine for the trust-critical number; human engineer reviews and approves all client-facing deliverables before release.
Liability if a managed client is breached	Human-in-the-loop accountability; clear scope and terms on the self-serve tiers; appropriate professional and cyber insurance; SOC 2 preparation underway (Section 9, Phase 2).
Well-funded competitor (Cynomi's \$37M Series B, Oneleet's managed-service model, or a Vanta/Drata SMB-tier launch)	Differentiate on proprietary scoring methodology, the managed services + platform model, direct-to-SMB distribution, and accumulated data and relationships rather than the AI alone — see Section 7.5 for the full landscape and watch items.
AI API cost or terms change	Model-flexible architecture; proprietary logic and scoring sit above any single provider; substitute models as needed.
Customer churn (“security feels done”)	Managed plans and continuous monitoring make the program perpetually valuable; compliance cycles and reporting anchor retention.
Scaling human expertise	The analyst console + AI co-pilot are designed precisely so each engineer manages many clients without linear headcount growth; the Section 10.4 training program ensures new engineers reach full certification and productivity on a defined timeline rather than an ad hoc one.
Expanding AI autonomy erodes trust or increases liability	The Section 9 autonomy roadmap is explicitly scoped to analysis, drafting, and detection — never to unilateral action in a client's environment. The human-approval gate is treated as a permanent architectural boundary, not a milestone to eventually remove.

SECTION 13

Summary

ShieldAIvCISO addresses a large, underserved, and — critically — a forced-demand market: tens of millions of small businesses that now must demonstrate a real security program but cannot afford to staff one. We enter with an affordable, working self-serve product, already live with an analyst console and monitoring agents in production rather than in development, and expand into high-value managed programs delivered by cybersecurity engineers who are amplified by our software and AI co-pilot.

Our defensibility is a system, not a feature: a proprietary, explainable NIST scoring engine; a human-in-the-loop model that makes our output trustworthy enough to sell; the data and relationships that compound with every client; and direct-to-SMB distribution that the best-funded names in the category — Cynomi, Vanta, Drata, Secureframe, Scrut Automation, and Oneleet — have each left structurally uncontested. A deliberate marketing strategy built on high-intent, relationship-driven channels (Section 8) and a roadmap that expands AI autonomy and feature depth without ever compromising the human-approval boundary (Section 9) extend that defensibility forward.

The product is already built and live, the founder brings a rare combination of operational, executive, and technical security credibility, and a technical engineer is already in motion, ready to go full-time on day one of this raise. This fundraise funds the specific eight-role team — laid out with qualifications, certification targets, and a funded readiness program in Section 10 — that staffs the platform and turns a working product into a scalable business.



· Confidential · September 2026